

THE AI BILLING DELEGATION STANDARD

ABDS: OAuth-based delegation for user-authorized AI resource consumption

Proposed open standard

Bounded, revocable, provider-enforced delegation of AI resource usage from a user-authorized account.

Marc Johnston | NeuroSync AI Dynamics Pty Ltd
Cape Town, South Africa

The consumer AI app economy has a billing problem

Inference-cost exposure, not model capability, blocks many useful consumer AI products.

Developer risk

A successful launch can become an immediate API bill liability.

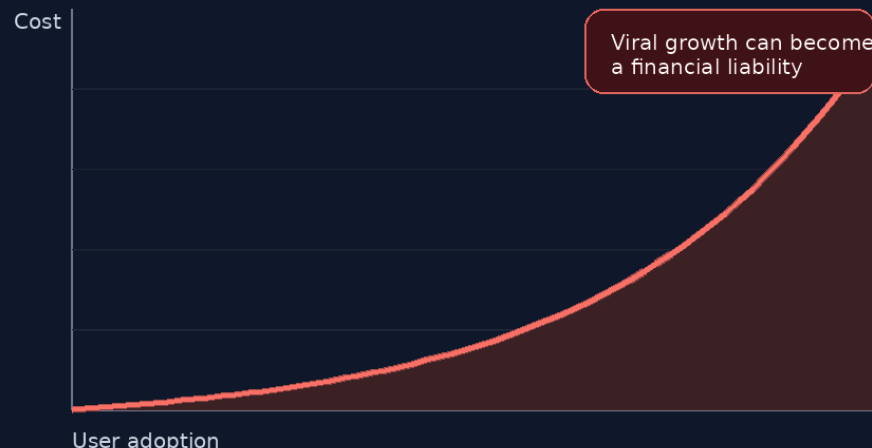
BYOK friction

Ordinary users do not understand API keys, token pricing, or provider dashboards.

Credit systems

Custom app credits add engineering overhead, support burden, and payment friction.

API Bill Risk



The ecosystem needs a standardized way to route bounded AI resource usage to the user's existing provider relationship.

AI lacks a consumer-grade delegation pattern

Ecosystem	Delegation pattern	What the user authorizes
Music	Provider account OAuth	Third-party app playback or playlist access
Cloud storage	Scoped app authorization	Access to selected files, folders, or account scopes
Payments	Bounded account-linked actions	Explicit permission for a financial workflow
AI APIs	Developer usually pays inference cost	No standard user-authorized resource delegation

ABDS proposes the missing delegation layer between consumer AI subscriptions and third-party AI applications.

ABDS in one sentence

ABDS lets users authorize bounded third-party consumption of provider-defined AI resource units, enforced through provider-side grants, short-lived execution tokens, usage ledgers, revocation controls, and explicit economic consent.

Consent

01

User sees economic consequence before approval

Grant

02

Provider creates bounded delegated grant

Token

03

Short-lived credential references the grant

Ledger

04

Provider records authoritative usage

Revoke

05

User can withdraw access at any time

The four-object architecture

User Subscription Entitlement

The user's underlying provider account or plan. Root economic relationship.



Delegated AI Grant

Server-side provider record defining app, user, cap, model scope, period, status.



Short-lived Execution Token

OAuth access token carrying identity, audience, scope, jti, and delegation_id.



Provider-side Usage Ledger

Authoritative record of usage, reservations, settlement, audit, and enforcement.

Critical design rule

The token identifies the grant. It does not carry quota state.

Quota truth lives in the provider grant and usage ledger, exposed through the Usage Introspection Endpoint.

This separation is what makes ABDS credible as a standards proposal.

ABDS should be an OAuth 2.0 profile

It should reuse proven OAuth patterns rather than introduce a new authentication protocol.

ABDS Delegation Profile	ABDS function	Standards-aligned pattern
OAuth Token Exchange	User authorization	Authorization Code Flow with PKCE
Resource Indicators	Execution-token issuance	OAuth Token Exchange
Authorization Code + PKCE	Target API binding	Resource Indicators
Revocation + Connected Apps	User withdrawal	Token revocation + connected-app dashboard
	App trust	Developer registration / verification

Strategic objective: interoperability. Reuse identity infrastructure and define only the AI-specific delegation layer.

Mutable quota state does not belong in JWT claims

Execution Token

Identity, audience, expiry, scope, jti, delegation_id, model_scope.

```
{
  "iss": "https://auth.provider.com",
  "aud": "https://api.provider.com",
  "sub": "user_id",
  "jti": "tok_xyz789",
  "delegation_id": "del_abc123"
}
```

- × quota_used
- × quota_remaining
- × quota_cap
- × quota_reset

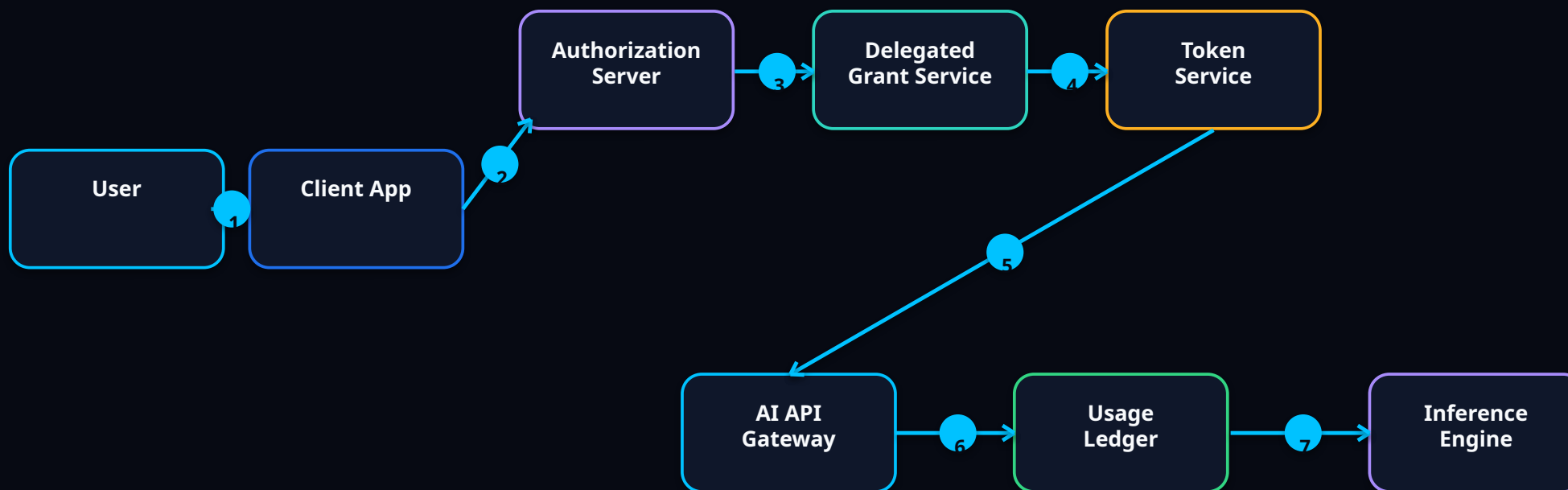
Provider Usage Ledger

Authoritative accounting and enforcement state.

- ✓ delegation_id
- ✓ quota_cap
- ✓ quota_used
- ✓ quota_remaining
- ✓ quota_period
- ✓ quota_reset
- ✓ grant_status
- ✓ usage_receipts

Token references grant, quota_reset
Ledger determines truth.

Provider-enforced execution flow



Gateway enforcement

The API gateway resolves `delegation_id`, validates token audience and scope, checks grant status, records usage against the ledger, and only then forwards permitted requests to the inference engine.

Economic consent must be explicit

Authorize AI Resource Access

Translation Studio by example.com wants permission to use a bounded portion of your AI account allowance.

Verified app	Translation Studio	●
Developer	example.com	●
Quota cap	500,000 standard text units / month	●
Model tier	Standard text models only	●
Renewal	Monthly until revoked	●

Allow bounded access

Cancel

Consent requirements

Verified app and developer identity

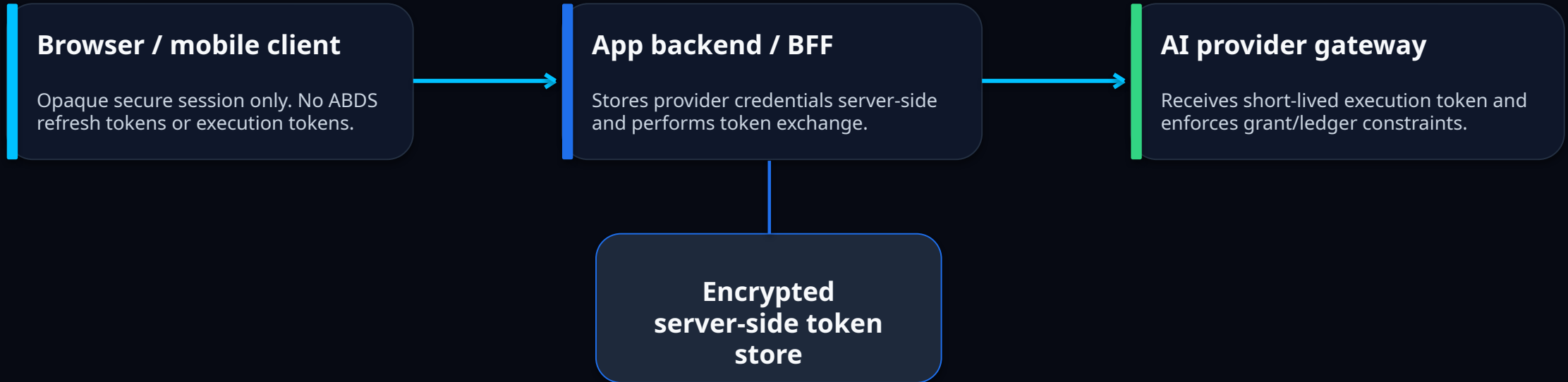
Concrete quota cap and reset period

Model class and renewal behaviour

Plain-language account impact

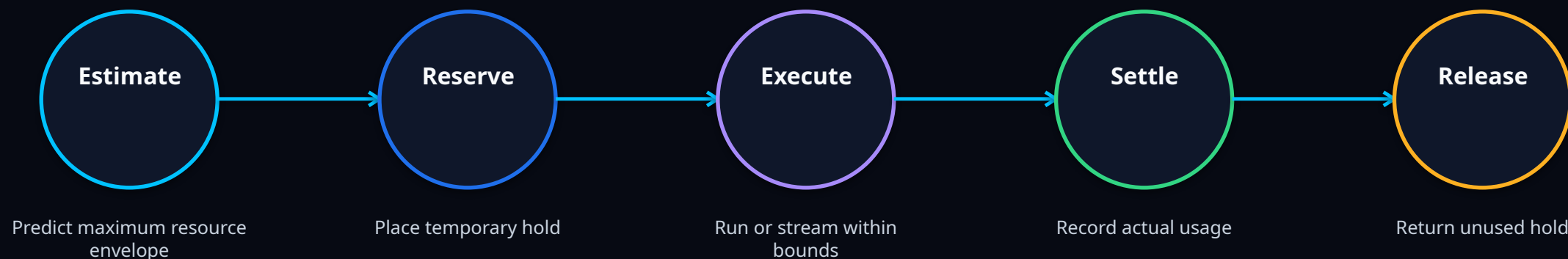
Clear revocation path and warnings for unverified apps

Sensitive AI execution tokens should not live in the browser



Recommended pattern: browsers receive only an opaque HttpOnly Secure session cookie. Refresh tokens and execution tokens remain on the application server and are never exposed to JavaScript-accessible storage.

Streaming and agentic workloads need reservation semantics



Error semantics

Insufficient delegated quota should return HTTP 429, not HTTP 402.

Standards posture

Reservation/settlement should be a v0.3 profile for streaming, batch, multimodal and agentic workloads.

Ecosystem expansion, not free compute

ABDS gives providers controlled delegation while reducing developer-side launch risk.

Provider control levers

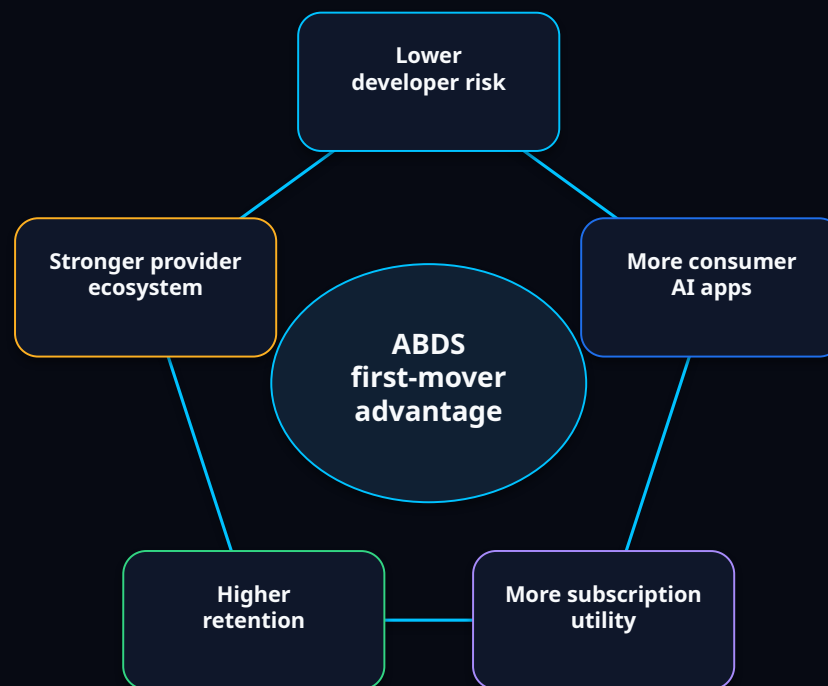
Delegated allowance separate from full subscription

Model-tier restrictions

Monthly caps and review thresholds

Paid delegated add-ons

Enterprise API lanes remain separate



CFO objection

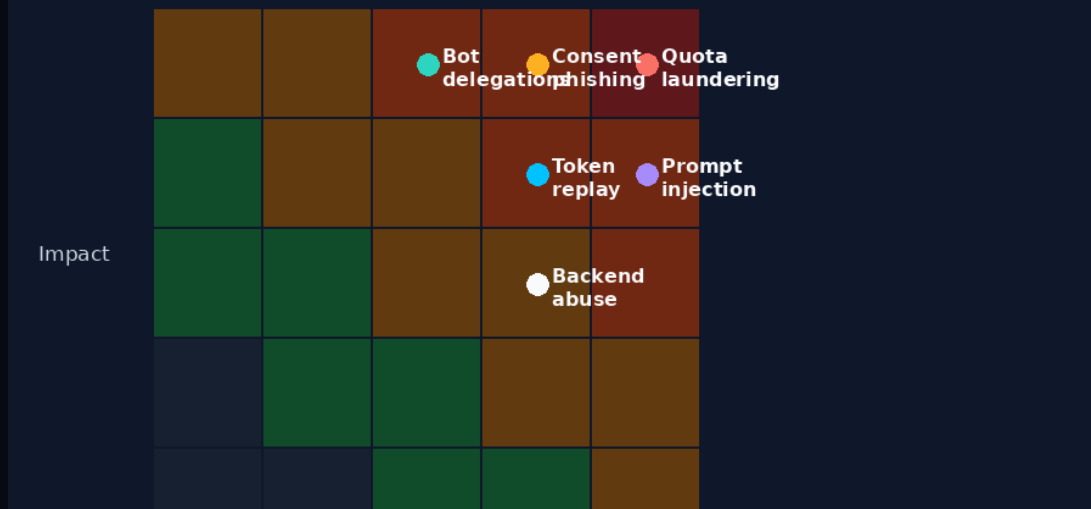
"This cannibalizes developer API revenue."

Counterargument: many consumer apps are not launching at all under the current billing model.

Provider economics improve when bounded delegation expands the consumer app ecosystem without exposing enterprise API lanes.

ABDS must be abuse-resistant by design

Threat Model Snapshot

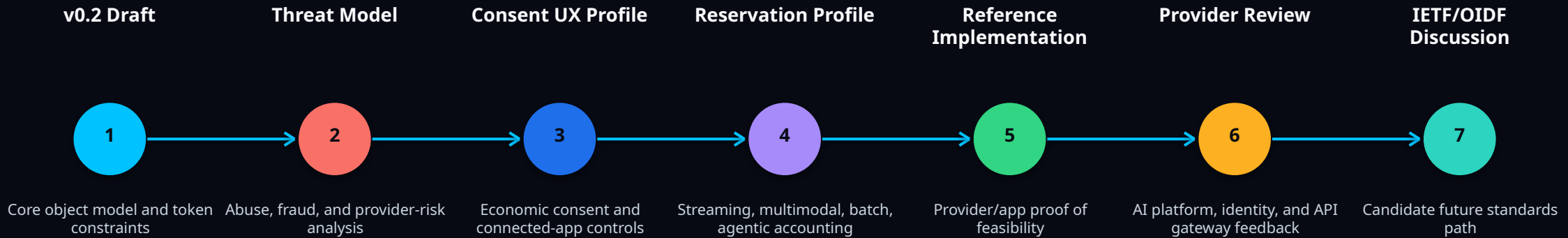


Priority threats

- Quota laundering and resale
- Consent phishing and spoofing
- Token replay and backend leaks
- Prompt-injection quota drain
- Bot-created delegations
- Model laundering through consumer subscriptions

Core mitigations: app verification, provider-side caps, risk scoring, rate limits, audit receipts, revocation dashboards, and proof-of-possession for higher-risk cases.

From open proposal to standards candidate



Positioning discipline

Say "candidate future IETF/OIDF discussion," not "approved IETF draft." ABDS should earn standards credibility through review, threat modelling, and reference implementation.

Review the ABDS proposal

Open technical review invited: OAuth, security, provider economics, resource accounting, and implementation constraints.

Closing thesis

ABDS is a proposed delegation layer between consumer AI subscriptions and third-party AI applications.

Marc Johnston | NeuroSync AI Dynamics Pty Ltd | Cape Town, South Africa



Technical appendix

Reference material for reviewers, engineers, and standards contributors.

Token and usage-introspection examples

Execution token claims

Short-lived OAuth access token. References delegation_id only.

```
{
  "iss": "https://auth.provider.com",
  "aud": "https://api.provider.com",
  "sub": "user_id",
  "exp": 1702592000,
  "jti": "tok_xyz789",
  "client_id": "app_123",
  "delegation_id": "del_abc123",
  "scope": "ai.inference.generate",
  "model_scope": ["standard-text-only"],
  "abds_version": "0.2"
}
```

Usage introspection response

Provider-authoritative quota state from /v1/quota.

```
{
  "delegation_id": "del_abc123",
  "status": "active",
  "quota_cap": 500000,
  "quota_used": 125000,
  "quota_remaining": 375000,
  "quota_period": "monthly",
  "quota_reset": "2026-07-01T00:00:00Z"
}
```

Design rule: quota fields belong in grant/ledger/introspection, not in bearer-token claims.

Threat model and mitigations

Threat	Consequence	Mitigation
Token replay	Delegated quota consumed by attacker	Short token lifetime, audience restriction, jti, optional DPOP
Quota laundering	Consumer subscriptions used as wholesale API supply	Velocity limits, app verification, aggregation detection
Consent phishing	Users authorize malicious consumption	Verified developers, warnings, step-up consent
Backend proxy abuse	Legitimate app drains quota under attack	Backend rate limits, bot detection, per-delegation throttles
Prompt-injection drain	Agentic loops consume unexpected quota	Budget caps, tool limits, stepwise settlement
Bot-created delegations	Automated abuse at provider scale	Account trust scoring, verification, fraud detection

Open design questions for reviewers

Quota units

Should ABDS standardize provider-defined units, or only the interface semantics?

Reservation

Should reservation/settlement be required for streaming or optional profile?

Enterprise ABDS

Should organizational delegation be a separate extension profile?

App verification

What quota thresholds require sensitive-scope style review?

Abuse reporting

Should providers expose usage receipts to users, apps, or both?

Standards venue

IETF OAuth WG, OpenID Foundation, W3C community group, or provider consortium?

ABDS should invite technical challenge early. These open questions make the proposal stronger, not weaker.